RAPPORT TECHNIQUE · VERSION PUBLIQUE

Enterprise OS Security

Conception, tests et renforcement d’une infrastructure Windows Server / Active Directory et Linux

Projet académique — UIR, département Cybersécurité

Projet collectif · Marwane Cissé et équipe · Sécurité des systèmes et administration

Environnement	Windows Server 2022 · Active Directory Domain Services · DNS · Ubuntu Server 22.04 · Kali Linux (laboratoire isolé)
Objectif	Étudier l’exposition initiale de systèmes d’entreprise et valider des mesures de durcissement à travers des scénarios contrôlés.
Démarche	Concevoir → Déployer → Tester → Analyser les journaux → Durcir → Réévaluer
Résultat	Le rapport académique décrit une réduction de la surface d’attaque et l’amélioration des contrôles d’accès et de l’authentification après durcissement.

Synthèse

Ce projet a consisté à construire un environnement de sécurité d’entreprise avec un contrôleur de domaine Windows et un serveur Linux, puis à étudier les risques de configurations insuffisamment protégées. Après une campagne de tests encadrés, l’équipe a analysé les traces système, renforcé les contrôles et réévalué les protections.

Le travail permet de comparer les modèles de sécurité Windows et Linux et d’appliquer concrètement des principes comme le moindre privilège, la défense en profondeur, la journalisation et la validation continue.

Note de publication : Ce document est une synthèse publique issue du rapport académique original. Les mots de passe, identifiants et détails opérationnels propres au laboratoire ont été exclus. Les captures et le rapport intégral restent dans la documentation du projet.

1. Architecture et environnement

Windows Server — gestion centralisée des identités

Installation de Windows Server 2022 en tant que contrôleur de domaine Active Directory, avec le service DNS associé. Configuration des unités d'organisation, des comptes, des groupes et des politiques de sécurité à l'échelle du domaine.

Linux Server — administration et accès distants

Déploiement d'un serveur Ubuntu 22.04 LTS dans un réseau virtuel isolé. Mise en place des comptes et des droits locaux, configuration du service SSH, politiques d'authentification via PAM et collecte des journaux système.

Laboratoire d'évaluation

Les tests ont été conduits dans un environnement virtualisé et confiné, distinct d'une infrastructure de production. Des configurations de départ volontairement insuffisantes ont permis d'observer les risques associés aux comptes, aux services exposés et aux contrôles d'accès.

2. Méthodologie du projet

- Concevoir : définir les composants, la segmentation du réseau, les rôles et les surfaces exposées.
- Déployer : installer les serveurs et paramétrer les services de domaine, SSH et les mécanismes de journalisation.
- Tester : évaluer les mécanismes d'authentification, l'exposition des services et les droits des utilisateurs dans le cadre autorisé du laboratoire.
- Détecter : analyser les journaux de sécurité et établir une chronologie des événements.
- Durcir : renforcer l'authentification, les permissions, les règles d'accès et la supervision.
- Valider : réaliser de nouveaux contrôles et comparer le comportement du système avant/après corrections.

3. Analyse de sécurité et détection

Environnement Windows

Les vérifications initiales ont porté sur la gestion des identités, les politiques de mots de passe, la protection des partages SMB et la maîtrise des privilèges. Les journaux Windows Security ont été analysés afin de repérer les événements de connexion, les échecs d'authentification, les modifications de comptes et les activités privilégiées.

Environnement Linux

Les analyses ont concerné les accès SSH, les permissions des fichiers, l'usage des privilèges et la qualité des politiques PAM. Les journaux d'authentification ont permis de suivre les tentatives de connexion, les changements de contexte utilisateur et d'autres événements administratifs pertinents.

Principaux constats du rapport

- Des politiques d'authentification faibles peuvent exposer les comptes aux tentatives d'accès non autorisé.
- Une gestion trop large des droits et des partages élargit l'impact potentiel d'un incident.
- La qualité des événements collectés et leur corrélation sont essentielles pour comprendre l'évolution d'un incident.
- Le durcissement doit être vérifié, plutôt que considéré comme acquis dès sa configuration.

4. Renforcement de la sécurité

Mesures appliquées au domaine Windows

- Renforcement des politiques de mots de passe et de verrouillage des comptes.
- Révision des appartenances aux groupes privilégiés et du principe du moindre privilège.
- Réduction de l'exposition des services et révision des droits sur les partages.
- Maintien et amélioration de la journalisation d'authentification et d'administration.

5. Durcissement Linux et validation

Mesures appliquées à Linux

- Renforcement des règles de complexité et de qualité des mots de passe via PAM.
- Sécurisation de SSH par authentification fondée sur les clés et restriction des accès administratifs distants.
- Mise en place de mécanismes de limitation des tentatives de connexion, notamment Fail2Ban.
- Révision des permissions, des droits sudo et de la journalisation.

Réévaluation après durcissement

Une nouvelle phase de validation est décrite dans le rapport pour les deux environnements. Elle compare les conditions d'accès, la résistance des mécanismes de protection et la visibilité des événements dans les journaux après application des mesures.

Selon la conclusion du rapport académique, les corrections ont réduit les risques précédemment identifiés et amélioré la résistance des systèmes aux scénarios initiaux. Il s'agit de constats issus d'un laboratoire pédagogique, pas d'un audit indépendant ou d'une garantie de sécurité complète.

6. Enseignements et limites

- L'architecture et les politiques d'identité déterminent en grande partie la surface d'attaque d'un système.
- L'analyse des journaux relie les observations de sécurité aux changements de configuration.
- Le contrôle des privilèges et la réduction des services exposés limitent les conséquences d'une compromission.
- Les résultats ont été obtenus en laboratoire isolé et ne doivent pas être généralisés à des environnements d'entreprise sans tests supplémentaires.

Source : rapport académique « Design, Implementation, Testing, and Hardening of an Enterprise Operating System Security Environment », UIR (35 pages).